

Resumen Técnico del Backend

1. Visión General

El backend es una plataforma empresarial integral construida sobre **NestJS 11** con **TypeScript** en modo estricto. Proporciona un conjunto unificado de servicios para:

- **Gestión de identidad y acceso** (autenticación, autorización, sesiones).
- **CRM** (captura y seguimiento de leads / oportunidades comerciales).
- **Marketing digital** (contenido de blog, redes sociales y campañas publicitarias).
- **Generación asistida por IA** (texto, imágenes, audio, análisis de virality).
- **Administración del sistema** (usuarios, roles, permisos, backups, auditoría).

La arquitectura es **híbrida**: los dominios simples usan un patrón CRUD plano (Service / Repository), mientras que los dominios complejos emplean **Arquitectura Hexagonal / DDD** con **CQRS** (CommandBus / QueryBus) para separar lecturas de escrituras y orquestar pipelines asíncronos.

2. Arquitectura y Stack Tecnológico

Capa	Tecnología
Framework	NestJS 11 (Node.js >= 20)
Lenguaje	TypeScript (strict, sin any)
ORM	Prisma 7 con adaptador pg para PostgreSQL
Base de datos	PostgreSQL (UUID v7 nativo, triggers, índices parciales)
Cache	Redis + @nestjs/cache-manager
Colas de trabajo	BullMQ sobre Redis
WebSockets	Socket.IO con adaptador Redis
Almacenamiento de objetos	Cloudflare R2 (compatible S3)
Email	Resend
IA / Generación	Google Gemini, Tavily, ElevenLabs, OpenAI, Anthropic
Autenticación	JWT (access / refresh), TOTP, Google OAuth
Autorización	CASL (RBAC + ABAC con condiciones JSONB)
Rate Limiting	@nestjs/throttler (múltiples tiers)
Observabilidad	OpenTelemetry, Pino (logging estructurado)
Tests	Jest + ts-jest

Capa	Tecnología
Contenedores	Docker + docker-compose

3. Modelo de Datos Principal

3.1 Identidad y Seguridad

- **User:** perfil completo con soft-delete, geolocalización, flags de seguridad (TOTP, lockedUntil, mustChangePassword).
- **AuthSession:** sesiones de refresh token (SHA-256 hash), con revocación y metadata de dispositivo.
- **OtpCode:** códigos de uso único para login, verificación de email y reset de contraseña.
- **PasswordResetToken** / **PasswordSetupToken:** tokens seguros con TTL y protección contra replay.
- **PasswordHistory:** append-only de hashes previos para evitar reutilización.
- **BackupCode:** códigos de recuperación 2FA (bcrypt hash, single-use).
- **TrustedDevice:** dispositivos que pueden omitir 2FA por hasta 30 días.

3.2 CRM

- **Appointment:** captura de leads con estado de pipeline (New, Called, Pending, Declined), llamadas de seguimiento (JSONB), notas y coordenadas GPS.

3.3 Contenido y Marketing

- **Post:** entradas de blog con estados draft, published, scheduled, campos SEO (slug, meta tags) y relación a categoría.
- **BlogCategory:** categorías de blog con imagen.
- **SocialMediaGeneration:** generaciones de contenido para redes con scores de calidad, imágenes en R2 y ZIP descargable.
- **CampaignGeneration:** campañas publicitarias por etapas de funnel con status (pending, processing, completed, failed, partial).
- **CampaignStageExport:** artefactos exportados por etapa (ZIP, metadatos).

3.4 Empresa y Soporte

- **CompanyData:** datos fiscales y de contacto del usuario (1:1), incluyendo firma digital.
- **ContactSupport:** tickets de contacto/soporte con marca de lectura.

3.5 RBAC

- **Role / Permission:** catálogo de roles y permisos con sujeto/acción alineados a CASL.
- **UserRole / RolePermission / UserPermission:** pivotes con condiciones JSONB (ABAC) y listas de campos (field-level security).

3.6 Sistema

- **ActivityLog:** trilla de auditoría **append-only** que registra toda mutación de estado con actor, recurso, metadata y traceId.
 - **DatabaseBackup:** snapshots pg_dump subidos a R2 con checksum SHA-256.
-

4. Módulos y Funcionalidades

4.1 Autenticación (Auth)

Responsable de toda la identidad, sesiones y seguridad de acceso.

- **Registro:** creación de cuenta con verificación de email vía OTP.
- **Login:** email/password + desafío 2FA (TOTP) si está habilitado; salta 2FA si hay *trusted device* válido.
- **Refresh Token:** rotación de tokens con hash SHA-256 persistido por dispositivo.
- **Logout:** revocación de sesión individual o masiva (`logout all devices`).
- **Password Reset:** flujo seguro con token de 1 hora y uso único.
- **Password Setup:** invitación a nuevos usuarios con token de 72 horas.
- **Cambio de contraseña:** con validación de historial y política de expiración.
- **TOTP / 2FA:** setup por QR, enable/disable, verificación en login, códigos de respaldo (8 códigos).
- **Trusted Devices:** registro de dispositivos que omiten 2FA temporalmente.
- **Google OAuth:** vinculación y desvinculación de cuentas Google.
- **Gestión de sesiones:** listado de sesiones activas con metadata y revocación selectiva.
- **Perfil propio:** actualización de datos personales y foto de perfil (subida a R2).

4.2 Gestión de Usuarios (Users)

CRUD completo de usuarios con arquitectura CQRS.

- Crear, leer, actualizar, eliminar (soft-delete) y restaurar usuarios.
- **Bulk delete / Bulk restore** en una sola operación transaccional.
- Exportación de listas a CSV / XLSX / PDF.
- Verificación de unicidad de email y username.

- Cambio de contraseña por administrador y setup de contraseña inicial.

4.3 Roles y Permisos (RBAC)

- **Roles:** CRUD de roles con asignación de permisos. Rol `super-admin` es de sistema e inmutable.
- **Permisos:** catálogo de permisos granular (`módulo:acción`) mapeado a sujetos/acciones de CASL.
- **Asignación directa:** permisos individuales a usuarios con condiciones JSONB (por ejemplo, "solo mis registros") y listas de campos visibles.

4.4 CRM / Leads (Appointments)

Gestión de oportunidades comerciales capturadas desde formularios.

- Pipeline de estados: `New` → `Called` → `Pending` → `Declined`.
- Registro de llamadas de seguimiento en formato flexible (JSONB).
- Notas adicionales, coordenadas GPS y propietario asignado.
- Marcar como leído para control de notificaciones.
- Soft-delete, bulk ops y exportación.

4.5 Blog (Posts + Categorías)

Gestión de contenido editorial con asistencia de IA.

- **Posts:** título, slug único, contenido, excerpt, imagen de portada, SEO metadata, estado (`draft` / `published` / `scheduled`), fecha de programación.
- **Categorías:** CRUD con imagen, relacionado al autor.
- **Generación con IA:** research en tiempo real (Tavily) + redacción (Gemini) + generación de imagen hero + metadata SEO.
- **Posts sociales:** generación multi-plataforma con **quality loop** (hasta 5 iteraciones) validando scores de Human Writing Index, Virality, Engagement, ROI y Trend Alignment.
- Soft-delete, bulk ops, exportación y descarga ZIP con contenido, imágenes y metadatos.

4.6 Redes Sociales (Social Media)

Generación dedicada de contenido para redes sociales.

- Envío de tópico → encolado en BullMQ → procesamiento asíncrono.
- Research de virality (Tavily) + generación de texto (Gemini) + generación de imágenes.
- **Quality loop:** auto-regeneración si los scores no alcanzan umbrales críticos.
- Almacenamiento de artefactos en R2.
- Descarga ZIP con README, contenido por red, imágenes y reporte de calidad.

- WebSockets para notificaciones de progreso en tiempo real.

4.7 Campañas Publicitarias (Campaigns)

Generación de campañas de video publicitario por etapas de funnel.

- Etapas configurables: Awareness, Interest, Consideration, Conversion, Retention.
- Pipeline asíncrono (BullMQ):
 1. Research de virality (Tavily).
 2. Generación de guion y storyboard por etapa (Gemini).
 3. Generación de audio (ElevenLabs, best-effort).
 4. Generación de imágenes (Gemini, best-effort).
 5. Generación de PDF por etapa (PDFKit).
 6. Empaquetado ZIP por etapa (Archiver).
 7. Análisis de detección de IA y scoring.
 8. Subida a R2 y persistencia transaccional.
- Descarga individual por etapa o paquete completo.
- WebSockets para progreso en tiempo real.

4.8 Datos de la Empresa (Company Data)

Perfil empresarial vinculado 1:1 al usuario.

- Nombre comercial, ID fiscal, contacto, dirección completa, coordenadas GPS.
- Redes sociales (Facebook, Instagram, LinkedIn, Twitter).
- Firma digital (imagen subida a R2).
- Usado como contexto inmutable (snapshot) para generación de campañas.

4.9 Soporte al Cliente (Contact Support)

- Formulario de contacto: nombre, email, teléfono, asunto, mensaje.
- Consentimiento SMS.
- Marcado como leído para gestión interna.
- Soft-delete, bulk ops y exportación.

4.10 Auditoría (Activity Log)

- Trilla de auditoría **append-only** (sin updates ni deletes).
- Registra: acción, actor, tipo de recurso, ID de recurso, traceId, IP, user-agent y metadata JSONB.
- Consultable por administradores para compliance y debugging.

4.11 Backups del Sistema (Backup)

- Snapshots de base de datos vía `pg_dump`.
 - Trigger manual por API o programación diaria vía cron.
 - Estados: `PENDING` → `COMPLETED` / `FAILED`.
 - Subida a R2 con checksum SHA-256 para integridad.
 - Descarga de archivos de backup.
-

5. Flujos de Negocio Principales

5.1 Captura y Seguimiento de Leads

1. Lead completa formulario → crea `Appointment` con estado `New`.
2. Usuario interno revisa el lead, realiza llamadas de seguimiento (registradas en `JSONB`) y actualiza el estado.
3. Lead puede ser exportado o gestionado hasta su conversión o declinación.

5.2 Publicación de Contenido (Blog)

1. Usuario crea un post manualmente o solicita generación con IA.
2. Si usa IA: `research` → redacción → generación de imagen → metadata SEO.
3. Usuario revisa, edita y cambia estado a `published` o programa fecha (`scheduled`).
4. Publicación programada puede ser automatizada vía `scheduler`.

5.3 Generación de Contenido para Redes Sociales

1. Usuario envía tópico y selecciona redes.
2. Sistema encola job en BullMQ.
3. Procesador ejecuta: `research` + generación + `scoring`.
4. Si scores no pasan umbrales, regenera hasta 5 veces.
5. Mejor intento se persiste con advertencia de calidad si aplica.
6. WebSocket notifica al frontend; usuario descarga ZIP.

5.4 Generación de Campaña Publicitaria

1. Usuario selecciona nicho, ubicación, formato de video y etapas de funnel.
2. Sistema toma snapshot del nombre de empresa desde `CompanyData`.
3. Encola job en BullMQ.
4. Por cada etapa: genera guion, storyboard, audio, imágenes y PDF.

5. Al final: análisis de calidad, empaquetado ZIP, subida a R2.
6. Usuario monitorea progreso en tiempo real y descarga artefactos.

5.5 Administración de Acceso

1. Super-admin define roles y asigna permisos.
 2. Admin asigna roles a usuarios; permisos directos con condiciones de propiedad si es necesario.
 3. En cada request, el `Cas lGuard` evalúa acción + sujeto + condiciones contra la habilidad del usuario.
 4. Toda mutación de estado se audita automáticamente.
-

6. Servicios Transversales (Infraestructura Compartida)

6.1 Transaccionalidad

Toda escritura que muta más de una fila (o entidad + auditoría) se ejecuta dentro de una transacción de base de datos. En módulos CQRS se usa `@Transactional()`; en CRUD plano se usa `runInTx()` explícito.

6.2 Cache

Redis para cacheo de consultas frecuentes. Las mutaciones invalidan el cache por patrón para mantener consistencia.

6.3 Almacenamiento de Archivos

Cloudflare R2 para:

- Fotos de perfil.
- Firmas digitales.
- Imágenes de blog y portadas.
- Reportes de análisis AI.
- ZIPs de campañas y redes sociales.
- Backups de base de datos.

6.4 Colas Asíncronas (BullMQ)

Jobs de larga duración que no bloquean el hilo HTTP:

- Generación de campañas publicitarias.
- Generación de posts sociales.
- Backups de base de datos.

- Envío masivo de emails.

6.5 WebSockets

Notificaciones push en tiempo real para:

- Progreso de generación AI (porcentaje por etapa).
- Completitud de jobs en cola.
- Alertas del sistema.

6.6 Exportación de Datos

Motor compartido para exportar listas filtradas a:

- CSV / XLSX (exceljs).
- PDF (pdfkit).

6.7 Sanitización y Seguridad

- Validación de entrada con **Zod v4** (sin `class-validator`).
- Sanitización de contenido HTML con `sanitize-html` (OWASP).
- Protección CSRF con `csrf-csrf`.
- Headers de seguridad con Helmet.
- Prevención de parameter pollution con HPP.

7. Baseline de Seguridad

Control	Implementación
Autenticación	JWT access corto + refresh token rotativo con hash SHA-256
2FA	TOTP (RFC 6238) + códigos de respaldo (bcrypt)
Trusted Devices	Cookie segura con token UUID; hash SHA-256 en DB; TTL 30 días
Bloqueo de cuenta	10 fallos consecutivos → lockout 15 minutos
Autorización	CASL con RBAC (roles) + ABAC (condiciones JSONB) + field-level security
Rate Limiting	Múltiples tiers por endpoint (global, auth, generación AI, export)
Sanitización	Zod v4 para schemas; sanitize-html para contenido enriquecido
Auditoría	ActivityLog append-only en toda mutación de estado

Control	Implementación
Almacenamiento de secretos	Tokens raw nunca persistidos; siempre hashes (SHA-256, bcrypt)
Transporte	HTTPS obligatorio; headers de seguridad (Helmet); CSRF

8. Estrategia de Eliminación de Datos

- **Soft-delete** (campo de `letedAt`) para entidades de negocio críticas: usuarios, citas, posts, categorías, contactos, roles, permisos.
- **Hard-delete** para contenido efímero: generaciones de campañas y redes sociales (para evitar costos de almacenamiento y dar control total al usuario).
- En ambos casos, la trilla de auditoría (`ActivityLog`) permanece como registro inmutable.

9. Resumen de Endpoints por Dominio

Dominio	Operaciones principales
Auth	Registro, login, logout, refresh, 2FA, TOTP, Google OAuth, reset/setup password, sesiones, dispositivos, perfil
Users	CRUD, bulk delete/restore, export, cambio de contraseña
Roles	CRUD, asignar permisos
User Permissions	Asignar/quitar permisos directos a usuarios
Appointments	CRUD pipeline, mark read, bulk ops, export
Posts	CRUD, generación AI, publicación programada, bulk ops, export, ZIP social
Blog Categories	CRUD
Social Media	Generar contenido, listar, descargar ZIP
Campaigns	Generar campaña, ver status, descargar por etapa / completo, eliminar
Company Data	Leer / actualizar perfil empresarial, subir firma
Contact Support	CRUD, mark read, bulk ops, export
Activity Logs	Listar auditoría
Backups	Ejecutar manual, listar, descargar, estado
